Motor Antifraude Pix

Integrantes: Hugo Gomes · Leandro Apolinário Leite · Mateus Carósio
Data: 18/10/2026
Versão das regras: 7.3

> A especificação vigente é a RFC v7.3. A v7.3 amplia o perfil de folha para despesas operacionais agendadas, exigindo evidências recentes e limites aprovados.

Como o motor de decisão funciona

O motor recebe um pedido de Pix, compara com o histórico local do pagador, do destinatário e do dispositivo e devolve a decisão (`approved`, `two_factor_required` ou `rejected`) antes de o dinheiro sair, em poucos segundos e sem consulta externa. Cada regra é uma função pura: recebe o evento e o histórico e devolve pontos e o motivo observado. O motor soma os pontos, aplica tetos por família e mapeia o total em um status. Cada regra acionada fica gravada para auditoria.

Passo a passo de um `POST /pix/transaction`:

1. Valida e normaliza o evento (documentos só com dígitos, datas em UTC) e calcula o `payload_hash`.
2. Abre uma transação PostgreSQL e trava o `id`, o pagador e a conta destino com `pg_advisory_xact_lock`.
3. Se o `id` já existe: mesmo hash devolve a análise gravada (`200`); hash diferente devolve `409`.
4. Carrega o histórico local (janelas relativas à `transaction_date` do evento), monta uma única vez o perfil do pagador e de cada contraparte (v6) e junta o `context` do EPP, quando houver.
5. Roda a checagem de integridade C1 (só EPP), executa as regras em ordem fixa, aplica os tetos, soma e define o `status`.
6. Grava evento, análise e regras acionadas na mesma transação e devolve `201`.

Há três blocos de lógica:

- **Núcleo Pix (R1–R12, R28, R29, R33):** sempre avaliado, para qualquer pedido de Pix.
- **Contexto EPP (R13–R27, R30–R32):** só quando o chamador é uma conta compartilhada de empresa de pequeno porte (EPP), em que vários sócios criam e aprovam pedidos, e envia o bloco opcional `context` (sócio autor, saldo livre, limites, mudanças de controle). Nesse caso, algumas regras do núcleo são ajustadas ou substituídas. Sem `context`, valem exatamente as regras do núcleo.
- **Checagem de integridade C1 (EPP):** não pontua; garante que o que foi aprovado é o que está sendo executado.

O contrato do desafio não muda: o payload de exemplo, sem `context`, é aceito e analisado só pelo núcleo. O `context` é uma extensão opcional da entrada, e a saída continua sendo `key`, `status` e `metadata`.

Configuração versionada das regras

Os parâmetros ativos ficam em `src/config/rulesets/active.json`, agrupados por regra, junto com as regras habilitadas, implementações selecionadas, eventuais substituições de pontos, tetos por família e faixas de decisão. Valores monetários terminados em `_CENTS` são centavos. A configuração é validada inteira na inicialização; chaves ausentes ou desconhecidas, tipos incorretos, valores fora dos limites e o desligamento da C1 impedem a API de iniciar. Cada processo mantém uma cópia imutável. Ao publicar a mudança, todas as instâncias precisam trocar para a mesma versão; não use uma implantação gradual que deixe processos com versões diferentes atendendo tráfego ao mesmo tempo.

Para alterar um limite, edite o parâmetro da regra, aumente `ruleset_version`, revise a mudança no Git e reinicie/publique todas as instâncias com a nova versão. O rollback consiste em restaurar a versão anterior da configuração e publicar novamente. Cada decisão registra `metadata.rules_version` e `metadata.ruleset_hash`, que identificam a configuração exata. A configuração não aceita expressões, Python nem SQL.

Uma mudança de fórmula fica no módulo da regra correspondente. Preserve a implementação publicada (`v1`), registre a nova função em `src/rules/registry.py` com outro nome (`v2`) e selecione-a em `rule_implementations`. A API falha na inicialização quando a implementação selecionada não está registrada. Aumente `ruleset_version` para qualquer mudança de fórmula ou parâmetros. Para uma regra com faixas internas de pontos, um `point_overrides` numérico aplica o mesmo peso em todas as faixas; sem substituição, permanecem os pontos definidos pela regra.

A versão 5 nasceu de uma revisão de brechas da versão 4: cenários em que o motor deixava passar fraude (sócios coniventes, esvaziamento em fatias, fracionamento por documento, agendamento como atalho, conta nova sem histórico). O que cada brecha mudou está na seção Brechas analisadas e como a v5 responde. A versão 6 revisou o que a v5 ainda fazia por contagem ou por valor absoluto: o "recorrente" que bastava ser pago 3 vezes, o R1 que cobrava o mesmo de todo pagador e a falta de uma regra que olhasse a história de cada contraparte (seção Revisão v6). O que ficou de fora de propósito está em Limitações conhecidas e roadmap.

Regras

Os parâmetros são pontos de partida, calibrados com os cenários de teste. Cada linha explica o porquê da regra e de cada número escolhido. Regras marcadas com **(v5)** ou **(v6)** são novas ou foram revisadas nessas versões.

Perfil e contraparte recorrente (v6)

O motor monta **uma vez por evento** um perfil, a partir das consultas agregadas que já fazia (não há tabela nem coluna nova), e as regras leem dele em vez de recalcular o próprio histórico:

- **Valor típico:** mediana e quantidade dos últimos 20 Pix não rejeitados do pagador (no EPP, por `responsibility_id` quando houver, como no R4).
- **Aparelhos:** `device_id` dos últimos 20 Pix não rejeitados (no EPP, do autor).
- **Horário habitual:** horas em que o autor já operou (R19).
- **Contrapartes:** para cada documento destino que o pagador pagou nos últimos 180 dias (Pix não rejeitados, qualquer conta): quantidade de Pix, data do primeiro, soma e maior valor.

Contraparte recorrente. Um documento destino é recorrente quando cumpre as quatro condições:

1. ≥ 3 Pix anteriores do pagador (no EPP, da conta da empresa);

2. o primeiro foi há ≥ 30 dias;
3. a soma deles é ≥ R$ 1.000;
4. o valor atual está **dentro da faixa**: ≤ 2× o maior Pix anterior para essa contraparte. Nas regras que olham uma janela (R29), a soma da janela, contando o atual, é que precisa estar dentro da faixa, e "anteriores" são os Pix antes do início da janela.

Na v5 bastava a contagem (≥ 3 Pix), e era exatamente o ponto fraco: três Pix de R$ 5 compravam a isenção para dividir depois R$ 6.000 em quatro Pix. Agora a relação precisa ter tempo, soma e um valor compatível com o que já foi pago. Os números (30 dias, R$ 1.000, 2×, 180 dias) são pontos de partida, como os demais. A condição de valor dentro da faixa é a que impede que "recorrente" vire um passe livre para qualquer valor.

Núcleo Pix (R1–R12, R28, R29, R33)

Regra	Lógica	Parâmetros	Por quê
R1 — Limite (v6)	O valor do Pix é alto para este pagador.	`amount` ≥ R$ 5.000 **e** uma das duas: pagador sem perfil de valor (< 5 Pix não rejeitados) ou `amount` ≥ 3× a mediana dos últimos 20 Pix não rejeitados. Não pontua para contraparte recorrente com valor dentro da faixa. **+2**	Valor alto aumenta a exposição, mas não prova fraude: com 2 pontos, sozinho leva só a 2FA. R$ 5.000 continua sendo o piso de exposição: abaixo dele nada muda. Na v5 os +2 valiam para todo Pix acima do piso, e quem paga o aluguel de R$ 6.000 todo mês ao mesmo locador levava 2FA todo mês, o que contradiz a regra do histórico de confiança. Agora valem para quem não tem perfil para comparar, para o valor que supera bastante o padrão (3×; o R4 exige 5×) e para fora de uma relação já conhecida.
R2 — Velocity	Rajada de Pix do mesmo pagador.	≥ 5 Pix em 60 s, contando o atual e qualquer status. **+2**	Uma pessoa raramente faz 5 Pix em um minuto; um script faz. Conta qualquer status porque as tentativas rejeitadas são justamente o sinal da rajada.
R3 — Montante acumulado	Valor fatiado para escapar do limite individual.	Soma do pagador em 10 min ≥ R$ 10.000, com ≥ 2 Pix na janela. **+2**	R$ 10.000 é o dobro do piso do R1: quem fatia precisa ultrapassar bastante o limite individual. Exigir 2 Pix evita contar duas vezes um único Pix grande, que o R1 já cobre. 10 min é curto o bastante para ser uma sequência única.
R4 — Desvio de perfil (v6)	O valor é incompatível com o padrão do pagador.	`amount` ≥ 5× a mediana dos últimos 20 Pix não rejeitados; histórico ≥ 5 Pix; `amount` ≥ R$ 500. Não pontua para contraparte recorrente com valor dentro da faixa. **+2**	A mediana resiste a valores atípicos (a média seria puxada por um Pix grande antigo). 20 Pix dão um perfil recente; 5× evita a oscilação normal; o piso de R$ 500 evita disparar em valores pequenos; o histórico mínimo evita inventar perfil de cliente novo. A exceção da v6 existe porque quem faz muitos Pix pequenos tem mediana baixa, e o aluguel mensal pareceria um desvio todo mês mesmo com o R1 relativo; a relação já conhecida com a contraparte é a explicação do valor.
R5 — Contraparte nova (v6)	O pagador nunca pagou essa conta destino.	Nenhum Pix anterior para a conta; histórico ≥ 3 Pix; `amount` ≥ R$ 1.000 e, com histórico ≥ 5 Pix, também ≥ a mediana do pagador (valor relevante para o perfil). **+1**	Destinatário novo é contexto, não motivo isolado (o aluguel do novo locador é legítimo). O histórico mínimo impede que o primeiro Pix de todo cliente pontue; o piso evita ruído em valores baixos. Na v6 o piso acompanha o perfil: para quem costuma pagar R$ 4.000, um novo destinatário de R$ 1.500 é ruído. Conhecer a contraparte continua sem tirar pontos aqui; o R5 só fica neutro.
R6 — Destino recém-aberto	A conta destino foi aberta há pouco.	Conta destino com ≤ 30 dias na `transaction_date` (tempo decorrido) e `amount` ≥ R$ 1.000. Se o R8 disparar, vale a soma da janela dele. Sem `opening_date` do destino, não pontua. **+2**	Contas recentes concentram risco de conta de passagem. 30 dias evita a fronteira apertada de 7 dias. O piso de R$ 1.000 é o mesmo teto por Pix do R8; por isso, quando há fracionamento, o R6 olha a soma e não cada Pix.
R7 — Dispositivo novo	O pagador usa um aparelho que nunca usou.	`device_id` fora dos últimos 20 Pix não rejeitados do pagador; histórico ≥ 3 Pix; `amount` ≥ R$ 500. **+2**	Trocar de aparelho é legítimo, por isso só pontua com perfil existente (3 Pix bastam para haver um aparelho habitual) e valor relevante. 20 Pix é a mesma janela do R4.
R8 — Fracionamento	Valor dividido em vários Pix pequenos para a mesma conta.	≥ 3 Pix do pagador para a mesma conta destino em 5 min, cada um < R$ 1.000, com soma ≥ R$ 2.000. **+2**	Pega quem fica abaixo do piso de R$ 1.000 do R5 e do R6. Três Pix e soma de R$ 2.000 diferenciam fracionamento de dois pagamentos legítimos seguidos.
R9 — Destino concentrador	A conta destino recebe de muitos pagadores em pouco tempo.	Conta destino recebeu de ≥ 5 pagadores distintos em 60 min, soma ≥ R$ 10.000, contando o Pix atual. Não vale para destinatário CNPJ com conta aberta há > 30 dias. **+3**	Padrão de conta de passagem. 5 pagadores distintos em uma hora é incomum fora do comércio; o piso de R$ 10.000 evita pontuar vaquinhas pequenas. Vale 3 porque envolve várias vítimas, mas ainda leva só a 2FA se estiver sozinha. A exceção protege comerciantes legítimos.
R10 — Pagador recente (v5)	A conta pagadora é nova.	Conta pagadora com ≤ 30 dias e `amount` ≥ R$ 2.000. **+1**; **+2** se o pagador tem menos de 3 Pix no histórico.	A idade da conta é um sinal complementar. Na v4 valia sempre 1, mas conta nova também não tem histórico mínimo, e sem ele R4, R5 e R7 não avaliam: o primeiro Pix de R$ 4.900 de uma conta de 10 dias saía `approved`. Sem perfil nenhum, o R10 é a única proteção, por isso pesa 2 e leva a 2FA. O piso de R$ 2.000 continua porque conta nova, sozinha, não é suspeita.
R11 — Deslocamento impossível	Dois Pix do mesmo pagador em lugares incompatíveis.	Geolocalização nos dois Pix; anterior há ≤ 60 min; distância ≥ 50 km; velocidade implícita > 900 km/h. **+3**	Sugere sessão usada de outro lugar. 900 km/h é a ordem de um voo comercial; 50 km filtra ruído de GPS; 60 min mantém a comparação em Pix consecutivos. Sem geolocalização, não pontua.
R12 — Dispositivo compartilhado	Um mesmo aparelho serve a várias titularidades.	Mesmo `device_id` usado por ≥ 3 documentos de pagadores distintos em 24 h. **+2**	Sugere fazenda de contas. 3 documentos deixa de fora um aparelho dividido por duas pessoas (casal, família); 24 h cobre o uso coordenado de um dia.
R28 — Valor colado no piso (v5, ajustada na v6)	O pagador repete valores logo abaixo do piso do R1 para escapar dele.	≥ 3 Pix do pagador em 24 h (contando o atual, qualquer status), cada um entre R$ 4.500 e R$ 4.999,99 (90% a 99,99% do piso do R1). Só avalia quando o R1 dispararia para um Pix de R$ 5.000 neste perfil: pagador sem perfil de valor, ou mediana < R$ 1.666,67 (R$ 5.000 ÷ 3). **+2**	O R1 é um degrau: R$ 4.999 vale 0 e R$ 5.000 vale 2, e quem conhece o piso fica logo abaixo. Um Pix assim é normal; três no mesmo dia são teste do controle. É a mesma ideia do R13 no EPP. Entra na família de valor. Com o R1 relativo, quem tem mediana alta não paga nada por cruzar R$ 5.000, então não há degrau para colar.
R29 — Fracionamento por	O valor é dividido em vários Pix para o	≥ 4 Pix do pagador para o mesmo documento destino (qualquer conta) em 60 min, contando o atual, soma ≥ R$ 5.000, sem teto	O R8 só vê a mesma conta, em 5 min e com cada Pix < R$ 1.000; seis Pix de R$ 1.499 passavam por R2, R3 e R8. 4 Pix em 1 h separam fracionamento de duas ou três compras seguidas; R$ 5.000 é o piso do R1, então dividir para fugir dele é o

documento (v5, revisada na v6)	mesmo destinatário, mesmo em contas diferentes e acima de R$ 1.000.	por Pix. Não vale para destinatário recorrente (v6): os Pix anteriores são os de antes do início da janela e a soma da janela precisa estar dentro da faixa. **+2**	caso. R8 e R29 compartilham teto, para o mesmo ato não contar duas vezes. Na v5 a isenção era só por contagem: três Pix de R$ 5 e, depois, quatro de R$ 1.499 passavam; agora a relação precisa de tempo, soma e valor compatível.
R33 — Salto de valor na contraparte (v6)	O valor é muito maior que tudo o que o pagador já enviou a essa contraparte.	≥ 1 Pix anterior não rejeitado do pagador para o mesmo documento destino (qualquer conta) nos últimos 180 dias; `amount` ≥ 5× o maior deles; `amount` ≥ R$ 1.000. **+2**	O R5 só pontua a contraparte nova. Depois de um Pix pequeno de "entrada", ela passa a ser conhecida, o R5 fica em 0 e um Pix grande passava limpo se a mediana do pagador fosse alta, porque o R4 compara com o pagador e não com a contraparte. 5× é o mesmo múltiplo do R4; o piso de R$ 1.000 evita ruído; sem Pix anterior o caso é do R5. Não precisa de exceção para recorrente, porque a comparação já é com a própria história da contraparte. Entra na família de valor.

Ajustes do núcleo quando há `context` (EPP)

Regra	No EPP	Por quê
R1	**Não avalia.**	O limite do sócio e a regra de aprovação já controlam o valor, e pagar fornecedor acima de R$ 5.000 é rotina de empresa. R4, R13 e R20 cobrem o desvio.
R2, R3, R5	Iguais; execução `scheduled` não pontua.	A folha em lote é uma rajada legítima, já aprovada; fornecedor novo é rotina (o R23 trata o caso da responsabilidade).
R4	**Adaptada:** mediana e histórico mínimo por `responsibility_id` do pedido, quando houver.	Folha e despesa pequena não dividem a mesma mediana.
R6, R8, R29	Iguais.	Conta de passagem e fracionamento são risco para qualquer pagador; fugir do limite do sócio também é fracionar.
R7	**Não avalia** (vale o R17).	Conta compartilhada tem vários sócios, cada um com seus aparelhos; o histórico por conta geraria falso positivo.
R9	**Não avalia** (vale o R26).	Os "pagadores distintos" do EPP são empresas; o R26 é a mesma regra com janela de 24 h.
R10	**Não avalia** (vale o R24).	A idade da conta pagadora é a ativação, e o R24 já a mede.
R11	**Não avalia** (vale o R18).	Dois sócios em cidades diferentes são normais; só faz sentido por autor.
R12	**Adaptada:** ≥ 3 `author_id` distintos, de empresas diferentes, em 24 h.	Sócios da mesma empresa no computador do escritório, ou um sócio com várias empresas, não são fazenda de aparelhos.
R28	**Não avalia** (vale o R13).	O R1 não existe no EPP, então não há piso para colar; o teto que importa é o do sócio, que o R13 mede.
R33	Igual; execução `scheduled` não pontua.	Mesmo motivo do R5: a execução cumpre um pedido já avaliado, e o pedido que criou o agendamento passa pelo R33 por completo.

Contexto EPP (R13–R27, R30–R32)

O "autor" é o sócio que criou o pedido; "recorrente" é a contraparte recorrente definida em Perfil e contraparte recorrente (v6): pagamentos da empresa (≥ 3, relação há ≥ 30 dias, soma ≥ R$ 1.000) e valor dentro da faixa. Antes bastava ter sido paga ≥ 3 vezes.

Regra	Lógica	Parâmetros	Por quê
R13 — Valor colado no limite	O autor testa o controle repetindo valores logo abaixo dele.	≥ 3 pedidos do autor em 24 h, cada um entre 90% e 99,9% do menor valor entre o limite do autor e o gatilho de aprovação; não conta pedido para contraparte recorrente (v6). **+2**	Quem testa o controle repete valores logo abaixo dele; 3 repetições separam teste de coincidência; mensalidade fixa não é teste.
R14 — Recriação após recusa	O autor refaz um pedido que outro sócio recusou.	Mesma contraparte; valor entre 80% e 120% do recusado; recusa por outro sócio em ≤ 24 h; cancelamento pelo autor não conta. **+2**	A recusa é um sinal de controle interno que o Pix de varejo não tem; a faixa de ±20% pega o valor ajustado para tentar de novo.
R15 — Aprovação disfarçada	O voto não vem de uma pessoa distinta do autor.	Evento `vote`: mesmo `device_id` do autor do pedido, ou mesmo IP e voto em < 10 s da criação. **+3**	O quórum exige pessoas distintas, e o EPP só barra o autor votando em si. IP sozinho é fraco (mesmo escritório); por isso exige o voto quase imediato.
R16 — Afrouxamento de controle seguido de uso (v5)	Controles são afrouxados pouco antes de o pedido sair.	Em ≤ 24 h depois de elevar limite, criar permissão, afrouxar regra de aprovação, definir substituto, **remover ou incluir sócio ou reduzir o quórum**, o pedido só passa por causa disso; ignora empresa com < 7 dias de conta. **+3**	Mexer nos controles pouco antes de usar é o padrão de abuso de um sistema de controles configuráveis. A v5 inclui mudança de quadro e de quórum: tirar um sócio ou baixar o quórum de 4 para 3 é o passo que antecede o desvio entre sócios coniventes. A empresa nova ainda está configurando tudo.
R17 — Dispositivo novo do sócio	O R7 aplicado ao histórico do autor.	`device_id` fora dos últimos 20 pedidos não rejeitados do autor; histórico ≥ 3; valor ≥ R$ 500. **+2**	Numa conta compartilhada, cada sócio tem seus aparelhos. Parâmetros iguais aos do R7.
R18 — Deslocamento e IP do sócio	O R11 por autor, com fallback por IP.	Janela ≤ 12 h; sem geolocalização, país do IP (base local) diferente do último IP do autor. **+3**	Sessão usada de outro lugar; a janela maior que a do R11 cobre voos longos.
R19 — Horário atípico	Pedido fora do horário habitual do autor.	Pedido imediato criado entre 0h e 5h (fuso do Brasil), valor ≥ R$ 1.000, autor com ≥ 10 operações e nenhuma nesse horário. **+1**	Usa a hora de criação, nunca a da execução, para não punir pagamento agendado; as 10 operações garantem que há hábito para comparar.
R20 — Esvaziamento (v5)	Saídas que drenam o saldo livre, de uma vez ou em fatias.	Saídas pagas com saldo livre nas últimas 24 h, contando a atual, somam ≥ 70% do saldo livre anterior à primeira delas (saldo livre antes deste pedido + saídas livres anteriores da janela) e ≥ R$ 5.000; pagamento coberto por reserva de responsabilidade não	Folha e imposto saem de reserva por desenho; saldo livre drenado é o sinal. Medir só por evento deixava passar três saídas de 60% do saldo restante (cerca de 94% drenado sem acionar nada); acumulado em 24 h, a

		conta. **+2**	segunda saída (84%) já dispara. O piso evita pontuar empresas com saldo pequeno.
R21 — Liberação de reserva seguida de saída	O dinheiro reservado é liberado e sai logo depois.	Liberação ou transferência entre reservas e, em ≤ 30 min, saída do autor ≥ 80% do liberado para contraparte nova. **+3**	Tira da empresa o dinheiro de impostos ou folha; a janela curta liga a saída à liberação.
R22 — Destino é sócio	O dinheiro vai para o CPF de um sócio.	Contraparte com o CPF de um sócio, valor ≥ R$ 2.000; não vale para contraparte recorrente (v6) com valor ±20% (pró-labore). **+1**	O dinheiro é da empresa, não dos sócios; isolada pesa pouco e soma com R13, R15 ou R20.
R23 — Contraparte nova para a responsabilidade	Responsabilidade previsível paga um destino fora do padrão.	Responsabilidade com ≥ 5 pagamentos e ≤ 3 contrapartes em 90 dias recebe pedido de contraparte nunca paga por ela, valor ≥ R$ 1.000. **+1**	Impostos e folha pagam sempre os mesmos destinos. Não soma com o R5: o mesmo fato não conta duas vezes.
R24 — Conta recém-ativada com saída grande	Conta nova movimenta muito.	Empresa imatura: saída externa ≥ R$ 5.000 vale 1; ≥ R$ 20.000 vale 2. Não pontua para pedido ou execução agendada que corresponda a um perfil de folha ativo e aprovado, dentro dos limites e com beneficiário autorizado. **+1 ou +2**	O perfil evita tratar uma folha legítima como atípica desde o primeiro mês. A exceção não vale para pagamentos avulsos, perfil vencido ou alterado, lote acima do limite, beneficiário não autorizado ou execução divergente.
R25 — Passagem entrada → saída	Dinheiro entra e sai quase de imediato.	Entradas externas em 24 h ≥ 3× a mediana das entradas externas em janelas de 24 h dos 30 dias anteriores; a saída atual é ≥ 80% dessas entradas e ocorre em ≤ 2 h para contraparte nova, em empresa ativa há ≤ 90 dias ou só com pagadores novos. O EPP informa `context.inflows_24h_median`; sem mediana positiva, a regra não é avaliada. **+3**	Compara o fluxo com o histórico da empresa; não usa um piso monetário fixo.
R26 — Destinatário em rede	O mesmo destinatário recebe de várias empresas.	Mesmo documento de contraparte com pedidos de ≥ 4 empresas em 24 h; total atual ≥ 3× a mediana dos totais recebidos em janelas de 24 h nos 30 dias anteriores (dias com atividade; exige ≥ 5 janelas ativas); não vale se for contraparte recorrente da empresa atual. **+3**	Compara a concentração de rede com o histórico do próprio destinatário. Sem amostra suficiente, a regra não é avaliada.
R27 — Sócio de muitas empresas (alerta)	Um mesmo CPF de sócio aparece em muitas empresas da plataforma em pouco tempo.	Mesmo CPF de sócio (`context.partner_documents`) em ≥ 3 `company_id` distintos com eventos nos últimos 30 dias, contando o atual. **0**	Só alerta: aparece em `reasons` para o back-office e não altera o status. Usa a atividade que o motor viu, não o cadastro, porque onboarding e cadastro de contas ficam fora do escopo.
R30 — Saída da empresa fora do padrão (v5)	Os sócios, somados, tiram da empresa muito mais do que ela costuma movimentar, cada um dentro do seu limite.	Saídas livres da empresa em 24 h (contando a atual; exclui pagamento coberto por reserva e execução `scheduled`) ≥ 3× a média diária dos 30 dias anteriores à janela e ≥ R$ 10.000; empresa ativada há ≥ 30 dias e com ≥ 10 saídas no período. **+2**	R13, R14 e R17–R19 olham um autor por vez, e o R3 só olha 10 min: quatro sócios abaixo do próprio limite passavam. É o único sinal que não depende de quem pede. 3× filtra a oscilação de fim de mês; o piso evita empresa pequena; sem 30 dias de histórico não há média confiável.
R31 — Destino ligado a sócio (v5)	O dinheiro vai para empresa ou pessoa ligada a um sócio, além do CPF dele (R22).	Contraparte é CNPJ do qual um sócio da empresa também é sócio, ou CPF de sócio de outra empresa da plataforma (`context.destination_partner_documents`, quando a plataforma conhece a contraparte); valor ≥ R$ 2.000; não vale para contraparte recorrente (v6) com valor ±20%. **+2**	Desviar para a segunda empresa do mesmo sócio contorna o R22, que só compara CPF. Pesa mais que o R22 (+1) porque exige vínculo comprovado, não coincidência. R22 e R31 são o mesmo fato e compartilham teto.
R32 — Credencial trocada seguida de saída (v5)	O autor troca senha, e-mail, telefone ou 2FA e logo depois tira dinheiro.	Em ≤ 24 h depois de `context.credential_changed_at` do autor, pedido imediato ≥ R$ 2.000; ignora autor com credencial criada há < 7 dias. **+2** (família de sessão, teto 4)	É o precursor clássico de tomada de conta e não era visto: o R16 olha controles da empresa, não credenciais do sócio. 24 h acompanha o R16; o piso é baixo porque o sinal é forte, e o teto de sessão impede que reprove sozinho.

Perfil operacional comprovado para EPP

O histórico não descreve uma padaria que precisa pagar funcionários ou fornecedores desde o primeiro mês. Para isso, o EPP mantém um perfil operacional versionado por empresa e responsabilidade, com `operation_type` `payroll` ou `operating_expenses`, e envia uma cópia no `context` do pedido agendado. Porte, faturamento e número de funcionários são sinais de capacidade, não verdades absolutas nem autorização automática: o perfil aprovado define limites explícitos por pagamento e por lote; esses valores não são calculados nem elevados pelo motor a partir dos números declarados.

O perfil só neutraliza a R24 se o pedido for agendado, estiver ativo, dentro da validade (no máximo 365 dias), respeitar o teto por pagamento e o teto total do lote, indicar um beneficiário autorizado pelo cadastro validado do EPP e tiver aprovação de pelo menos dois sócios diferentes do autor. Também exige uma evidência verificada para cada dimensão: porte, faturamento mensal e quantidade de funcionários. As evidências precisam ter referências e origens distintas, registrar o valor verificado correspondente ao perfil e ter sido verificadas nos últimos 90 dias. O motor falha fechado se faltar qualquer evidência, se ela estiver vencida ou se o valor não corresponder. O EPP continua aplicando seu fluxo normal de aprovação do pedido; o perfil não desativa as outras regras.

Na execução, o EPP envia a referência ativa do perfil e do lote. A R24 só é neutralizada se a referência e o total do lote coincidirem com o pedido armazenado e o Pix executado repetir valor, pagador, documento e conta destino do pedido ligado por `request_id` e `request_hash`. Se o perfil vencer, for revogado ou alterado, ou qualquer dado divergir, a R24 volta a aplicar os degraus de início frio. Cada mudança aprovada gera uma versão nova. A decisão registra `metadata.operational_profile` com o identificador, versão e lote; o snapshot com aprovações fica no `payload` JSONB do pedido.

No pedido, `context.operational_profile` contém `profile_id`, `version`, `operation_type`, `status`, `company_id`, `responsibility_id`, `company_size`, `monthly_revenue_cents`, `employee_count`, `evidence`, `max_payment_cents`, `max_batch_cents`, `expires_at` e `approvals` (`partner_id` + `approved_at`). Cada item de `evidence` contém `kind` (`company_size`, `monthly_revenue` ou `employee_count`), `reference_id`, `source`, `observed_value` e `verified_at`; não se enviam nem armazenam os documentos brutos no motor. O mesmo `context` contém `batch_id`, `batch_total_cents` e `beneficiary_authorized`. Na execução, `context.operational_profile_ref` contém `profile_id`, `version` e o estado atual (`active`, `inactive` ou `revoked`), além do mesmo `batch_id` e total.

O cadastro principal, a verificação documental e a validação dos votos continuam no EPP. A API aceita esses fatos apenas pelo canal interno autenticado (`INTERNAL-TOKEN`); esse token deve ficar restrito ao serviço EPP, que só deve emitir as referências de evidência após a verificação e afirmar `beneficiary_authorized` após conferir o destino em cadastro aprovado. As referências comprovam a trilha de verificação, não garantem que os documentos ou declarações sejam verdadeiros. O EPP deve confrontar fontes independentes, limitar conservadoramente os valores e revisar o perfil quando as evidências mudarem ou expirarem.

Checagem de integridade (C1, EPP)

Checagem	Lógica	Parâmetros	Por quê
C1 — Pedido ≠ voto ≠ execução (v5/v7.2)	O que foi aprovado precisa ser o que está sendo executado.	Em `vote` e `execution`, `context.request_id` e `context.request_hash` são obrigatórios (`422` se faltarem). O pedido deve existir, não estar `rejected` e ter o mesmo hash; a execução também precisa repetir valor, pagador, conta pagadora, documento e conta destino. Uma execução não rejeitada por pedido. **0 pontos; força `rejected` se falhar.**	A C1 v2 confere os campos financeiros além do vínculo por hash. Uma execução divergente não recebe a isenção do perfil operacional nem a isenção de pagamento programado.

Como as regras viram decisão

Ordem. A C1 roda primeiro (só em `vote` e `execution`) e, se acionada, força `rejected`. As regras aplicáveis são executadas em ordem fixa (R1 a R33), sem interromper na primeira que dispara. A ordem só deixa estável a lista de motivos. Cada regra acionada gera um `RULE_HIT` com os pontos antes do teto.

Tetos por família. O mesmo ato não deve contar várias vezes:

- Valor: R1 + R3 + R4 + R28 + R33 somam no máximo **3**.
- Fracionamento: R8 + R29 somam no máximo **2**.
- Controles internos (EPP): R13 + R14 + R16 somam no máximo **3**.
- Sessão do sócio (EPP): R17 + R18 + R19 + R32 somam no máximo **4**.
- Destino ligado a sócio (EPP): R22 + R31 somam no máximo **2**.

Faixas. O `risk_score` é a soma depois dos tetos:

Pontos	Status
0–1	`approved`
2–4	`two_factor_required`
≥ 5	`rejected`

O que o `risk_score` é. Uma pontuação ordinal, não uma probabilidade: 4 pontos não são o dobro do risco de 2, e a soma não diz "chance de fraude". Calibrar probabilidades exigiria dados rotulados de fraude confirmada, que o projeto não tem. Os cortes em 2 e 5 são decisões de política, revisáveis com o histórico de `RULE_HIT` gravado.

Quando pede 2FA. Com 2 a 4 pontos há dúvida, mas não risco claro: o cliente confirma que é ele mesmo e a transação segue. Um único sinal moderado (valor alto fora do perfil, destino recém-aberto, destino concentrador, dispositivo novo) leva a 2FA, nunca a `rejected`. Como valor alto soma no máximo 3, reprovar exige pelo menos 2 pontos vindos de outros sinais. Sinais de sessão do sócio, sozinhos, também nunca reprovam.

Exceções e histórico.

- Se o documento do pagador for igual ao do destinatário, R5, R6 e R9 não pontuam.
- **Pagamento programado (v5/v7.3).** A execução (`event` = `execution`, `origin` = `scheduled`) não pontua R2, R3, R5, R33 nem R17 a R19. O pedido (`event` = `request`) continua passando pelas outras regras. A R24 só é neutralizada para folha ou despesa operacional agendada com perfil ativo, três evidências recentes e coerentes, limites aprovados, destino autorizado e execução exatamente igual ao pedido. Sem perfil válido, vencido, revogado ou com divergência, a R24 segue valendo.
- O histórico de confiança (R1, R4, R5, R7, R17, R33 e a contraparte recorrente) exclui apenas Pix `rejected`. O motor não recebe o resultado do 2FA, e contar só os `approved` faria o cliente do aluguel cair em 2FA todo mês.
- O histórico de rajada e concentração (R2, R3, R8, R9, R11, R12, R28, R29) considera qualquer status, porque tentativas rejeitadas também revelam o padrão.

Quem aplica a decisão. O motor só decide e sugere; quem aplica é o chamador. No EPP, `two_factor_required` pode virar segundo fator do autor ou aprovação adicional de outro sócio, e `rejected` em um voto significa que o voto não conta. Em evento EPP com status diferente de `approved`, se alguma entre R16, R20, R21, R22, R30, R31 e R32 for acionada, `metadata.recommended_actions` traz `notify_all_partners`: o EPP deve avisar todos os sócios, inclusive os que não votaram, antes de liberar o dinheiro.

Motivos. `metadata.reasons` traz regra, pontos e valores observados, para auditoria. O chamador não deve exibir esse detalhe ao cliente final (mensagem genérica), porque os parâmetros revelados ensinam como ficar abaixo deles.

Exemplos.

- Cliente com mediana de R$ 200 que paga R$ 6.000 pela primeira vez a um locador, no aparelho de sempre: R1 (2, valor ≥ 3× a mediana) + R4 (2), limitados a 3 pela família de valor, mais R5 (1) = 4. Recebe 2FA.
- O mesmo cliente paga o 6º aluguel de R$ 6.000 ao mesmo locador (relação de 5 meses, maior Pix anterior de R$ 6.000): a contraparte é recorrente e o valor está dentro da faixa, então R1 e R4 não pontuam, e o R5 já era neutro. Total 0, `approved`. Na v5 recebia 2FA todo mês.
- Cliente com mediana de R$ 8.000 que, depois de mandar R$ 5 a um CPF, manda R$ 20.000 a ele: R1 não dispara (abaixo de 3× a mediana), R4 não dispara (abaixo de 5×) e o R5 está neutro, porque a contraparte já é conhecida. O R33 dispara (20.000 ≥ 5 × 5): 2 pontos, 2FA. Na v5 passava limpo.
- Cliente com mediana de R$ 4.000 que paga R$ 6.000 a um locador novo: R1 e R4 não disparam, R5 vale 1 (6.000 ≥ a mediana). Total 1, `approved`.
- Sessão sequestrada de um sócio, com aparelho nunca visto (R17, 2), às 2h10 (R19, 1) e saída de 87% do saldo livre (R20, 2): 5 pontos. É rejeitada.
- Pix do payload de exemplo do desafio (R$ 1.500, conta destino aberta 7 dias antes, pagador sem histórico): só o R6 dispara, 2 pontos, `two_factor_required`.
- Conta de 10 dias, primeiro Pix de R$ 4.900 para uma conta antiga: R1 não dispara (abaixo de R$ 5.000), R4, R5 e R7 não avaliam (sem histórico), R10 vale 2 por falta de perfil: 2FA. Na v4 valia 1 e saía `approved`.
- Empresa com 4 sócios, saída de R$ 40.000 (mais de 3× a média diária) para um CNPJ de outro sócio: R30 (2) + R31 (2) = 4, `two_factor_required` com `notify_all_partners`. Se o quórum foi reduzido 6 h antes, o R16 soma 3 e o total é 7: `rejected`.

Brechas analisadas e como a v5 responde

A versão 4 foi revisada procurando cenários em que o motor deixava passar fraude. Cada brecha abaixo virou uma regra, uma revisão ou uma limitação documentada.

Cenário de risco	Como passava na v4	O que a v5 faz
Sócios coniventes (3 de 4) aprovam saídas de aparelhos distintos	R15 não dispara (são pessoas distintas); R13, R14 e R17–R19 olham um autor por vez; R22 só compara CPF	**R30** (volume da empresa), **R31** (destino ligado a sócio), **R16** revisada (mudança de quadro e quórum), **R32** (credencial trocada) e `notify_all_partners`
Esvaziar o saldo livre em fatias	R20 media cada saída isolada: três saídas de 60% drenavam cerca de 94%	**R20** acumulado em 24 h
Dividir o valor entre contas do mesmo titular, com Pix acima de R$ 1.000	R8 exige mesma conta, 5 min e Pix < R$ 1.000	**R29** por documento, 60 min, sem teto por Pix
Ficar logo abaixo do piso de R$ 5.000	R1 é um degrau: R$ 4.999 vale 0	**R28** (3 Pix colados em 24 h)
Conta nova, sem histórico	R4, R5 e R7 desligam; só o R10 (1 ponto)	**R10** vale 2 sem perfil
Agendamento como atalho	Isenção do `scheduled` ambígua: criar o agendamento poderia escapar	Isenção só na execução; a criação é avaliada por completo
Editar valor ou destino depois da aprovação	Nada ligava voto e execução ao pedido	**C1** com `request_hash`
Tomada de conta por troca de credenciais	Não era um sinal	**R32**

O que o motor não resolve sozinho. Três sócios com credenciais válidas, votando em quórum válido, não são identificáveis só por regras: o motor enxerga mudança de comportamento (R30, R31, R16), não intenção. A proteção do sócio de fora é de produto: notificar todos os sócios, manter uma janela curta de contestação e registrar entrega e leitura da notificação. O motor contribui com a sugestão `notify_all_partners`. Se esse sócio responde ou não perante a lei é questão de jurídico e compliance.

Revisão v6: contraparte, perfil e valor relativo

A v5 ainda decidia algumas coisas por contagem ou por valor absoluto. Esta revisão procurou onde isso deixava fraude passar (falso negativo) ou travava cliente bom (falso positivo).

Furo	Como era na v5	O que a v6 faz
"Recorrente" por contagem	R13, R22, R26, R29 e R31 isentavam quem já foi pago ≥ 3 vezes; só R22 e R31 olhavam o valor (±20%). Três Pix de R$ 5 e, depois, quatro de R$ 1.499 passavam pelo R29.	**Contraparte recorrente** com tempo (≥ 30 dias), soma (≥ R$ 1.000) e valor dentro da faixa (≤ 2× o maior Pix anterior).
Valor absoluto	R1 dava +2 para todo Pix ≥ R$ 5.000, e o aluguel mensal de R$ 6.000 levava 2FA todo mês. Os pisos de R3, R5, R6, R7, R10, R28 e R29 também eram fixos.	**R1 relativo ao perfil** (sem perfil, ou ≥ 3× a mediana), com exceção para contraparte recorrente na faixa, que vale também no R4. R5 e R28 passam a acompanhar o perfil.
Camadas só somavam	Cada regra recalculava seu histórico. Depois do Pix pequeno de entrada o R5 ficava em 0, e um Pix grande passava se a mediana do pagador fosse alta.	**Perfil montado uma vez** e lido pelas regras; **R33** compara o valor com o maior Pix já enviado àquela contraparte.

O que ficou com piso fixo, de propósito. R3, R6, R7, R10 e R29 mantêm o piso absoluto na v6. R6 (conta de passagem), R7 (aparelho) e R10 (conta nova) protegem justamente onde o perfil não ajuda ou não existe, e R3 e R29 medem soma, em que o piso é a própria exposição. Trocá-los por "valor relevante para este perfil" fica no roadmap, depois de medir quantos Pix legítimos pontuam hoje só por causa do piso.

Risco aceito. A exceção do recorrente tem custo: quem constrói a relação (3 Pix, 30 dias, R$ 1.000) pode depois mandar até 2× o maior Pix sem pontuar no R1, no R4 ou no R29, e o R33 só dispara a partir de 5×. Uma escada de dobros passa (ver roadmap).

Limitações conhecidas e roadmap (não implementado na v6)

Itens abaixo são decisões de escopo, não esquecimentos: custam tabela nova, endpoint novo ou dado que o chamador ainda não envia. Nenhum deles está ativo, e nenhuma regra desta seção pontua.

Princípio para lavagem de dinheiro: padrões de AML entram como **alerta de 0 ponto para a fila do back-office**, como o R27 já faz. O falso positivo não trava o cliente, o `RULE_HIT` com 0 pontos não exige schema novo, e a decisão de comunicar ao COAF é do compliance. Bloqueio em tempo real fica só para quando a soma de pontos chega a 5.

Alerta (0 pt)	Lógica proposta	Por quê
A1 — Giro de 7 dias	Entradas externas ≥ R$ 20.000 em 7 dias e saídas ≥ 90% delas	O R25 só pega passagem em 2 h; lavagem real espalha a saída em dias
A2 — Ciclo	O destino pagou a origem nos 7 dias anteriores, com valor entre 80% e 120% do atual (A→B→A)	Movimento circular entre contas da plataforma; consulta local de 2 saltos
A3 — Fan-out	≥ 5 contrapartes novas distintas da empresa em 24 h	R5 e R23 olham uma contraparte por vez
A4 — Porte incompatível	Volume de 30 dias > 3× o faturamento mensal declarado (`context.declared_monthly_revenue`)	Volume incompatível com o cadastro; o dado só é lido, o onboarding segue fora do escopo
A5 — Conta dormente	≥ 90 dias sem movimento e saída ≥ R$ 5.000	O R24 só cobre conta nova
A6 — Quórum seletivo	≥ 3 pedidos ≥ R$ 5.000 em 30 dias aprovados sem voto nem ciência do mesmo sócio ativo	Sinal de que um sócio está sendo deixado de fora

Outros itens do roadmap:

- **Lista local de partes sinalizadas (`flagged_party`):** documentos e contas confirmados como mula ou fraude, alimentados pelo back-office; match gera `rejected`. É o bloqueio categórico que o desenho já prevê, e exige uma tabela e um jeito de popular.

- **Retorno de resultado:** o motor não sabe o resultado do 2FA nem se um Pix virou devolução. Um endpoint de resultado alimentaria o histórico e a lista acima.
- **Quarto lock por documento destino (EPP):** o R26 é por documento, mas o lock é por conta destino; quatro empresas pagando o mesmo documento, em contas diferentes e em paralelo, não se enxergam. O custo é serializar pagamentos a um CNPJ muito pagador, então precisa de medição.
- **Validação do relógio:** as janelas usam a `transaction_date` do chamador; data retroativa ou fora de ordem tira o evento das janelas dos outros. O motor confia no chamador.
- **Rampa longa de valor:** a mediana do R4 resiste até cerca de 10 passos de aumento gradual; uma rampa mais longa e lenta passa. Na v6, a faixa da contraparte recorrente (2× o maior Pix anterior) cria outra escada: dobros sucessivos a uma contraparte já recorrente passam por R1, R4 e R29, e o R33 só pega saltos de 5×. Uma mitigação possível é medir a faixa pela mediana da contraparte, e não pelo maior Pix.
- **Pisos relativos ao perfil:** R3, R6, R7, R10 e R29 seguem com piso fixo na v6 (ver Revisão v6). Medir quantos Pix legítimos pontuam só pelo piso antes de trocar.
- **Engenharia social:** o sócio verdadeiro, no aparelho verdadeiro, induzido a pagar. Nenhuma regra pega bem; a mitigação é de produto (aviso para contraparte nova de valor alto).
- **Machine learning:** continua fora, por falta de dados rotulados. As regras gravadas por evento são a base auditável para isso.

API

`POST /pix/transaction`

Valida, analisa e registra um evento Pix, retornando a decisão. É idempotente pelo `id` do evento.

Campos de entrada:

- `id`: identificador único do evento (o Pix ou, no EPP, o voto).
- `amount`: valor em centavos, inteiro positivo.
- `transaction_date`: data e hora com fuso.
- `source_account`: agência, número, data de abertura e `owner.document_number` (CPF ou CNPJ) do pagador.
- `destination_account`: participante (ISPB), agência, número, data de abertura e `owner.document_number` do destinatário. No EPP, a data de abertura é opcional.
- `source`: `device_id`, `channel`, `ip` e `geolocation` (latitude e longitude, opcional).
- `context` (opcional, enviado pelo EPP): `event` (`request`, `vote` ou `execution`), `origin` (`immediate` ou `scheduled`), `company_id`, `author_id`, `responsibility_id` e os fatos que só o EPP conhece (saldo livre, limites, ativação da conta, mudanças de controle, liberação de reserva e documentos dos sócios). `request_id` e `request_hash` são obrigatórios em `vote` e `execution`; `credential_changed_at` e `destination_partner_documents` são opcionais. Para uma folha ou despesa operacional autorizada, o pedido agendado pode incluir `operational_profile` com tipo, porte, faturamento, número de funcionários, três evidências recentes e distintas, limites por pagamento/lote, validade e aprovações; também inclui `batch_id`, `batch_total_cents` e `beneficiary_authorized: true`. A execução correspondente inclui `operational_profile_ref` (ID, versão e estado atual) e o mesmo lote/total.

Resposta (`key`, `status`, `metadata`): `metadata` traz `risk_score`, `reasons` (as regras acionadas com pontos e valores observados), `rules_version`, `ruleset_hash` e `recommended_actions` (lista, pode ser vazia).

Status:

- `201`: análise criada.
- `200`: mesmo `id` e mesmo payload; devolve a análise já gravada, sem reprocessar.
- `400`: corpo ilegível ou JSON malformado.
- `409`: mesmo `id` enviado com payload diferente.
- `422`: campo ausente ou de tipo errado, `amount` não inteiro ou ≤ 0, data sem fuso, documento sem 11 ou 14 dígitos, latitude ou longitude fora da faixa, `context` com `event` inválido ou sem `author_id`, ou `vote`/`execution` sem `request_id` e `request_hash`.
- `500`: falha interna; tudo é revertido e o reenvio é seguro.

`GET /pix/transaction/{id}`

Consulta o evento Pix armazenado e sua análise pelo `id` do evento (não o `key`). Somente leitura.

- `200`: `key`, `status`, `metadata` e `transaction` com o payload original gravado.
- `404`: não existe análise para o `id` informado.

Banco de dados

O sistema usa PostgreSQL e mantém o evento, a análise e as regras acionadas.

`PIX_TRANSACTION`

Armazena todo evento que passou pela validação: `id` (chave primária e idempotência), `payload_hash`, valor em centavos, data da transação em UTC, dados normalizados do pagador e do destinatário, dispositivo, canal, IP, geolocalização opcional, campos EPP, `context` para reproduzir a decisão, payload original e data de recebimento. `400`/`422` são recusas de validação e não viram eventos; aprovações, exigências de 2FA e rejeições de regra são persistidas. O snapshot versionado de `context.operational_profile`, incluindo referências e valores verificados das evidências, fica junto ao pedido para auditoria; documentos brutos e cadastro principal permanecem no EPP. Índices por pagador, destino, dispositivo e autor apoiam as consultas de histórico.

O Compose mantém os dados em um volume nomeado (`qihackathon-validacao-de-pix-postgres`), portanto recriar o container não recria o histórico. Em um banco novo, a imagem aplica `database.sql` e as migrations numeradas na inicialização. Em instalações que já tinham um volume antes desse bootstrap, faça backup e aplique as migrations ainda não executadas em ordem, por exemplo:

```
for migration in database/migrations/*.sql; do
  docker compose exec -T db psql -U bootcamp -d epp_conta_compartilhada < "$migration"
done
```

Requisições recusadas na validação (`400` ou `422`) não viram evento nem análise; todo evento válido fica gravado e consultável pelo `GET`.

Reenvio idêntico (`200`) retorna a análise existente; conflito de `id` (`409`) e payload inválido (`400`/`422`) não criam uma linha de tentativa. O histórico abaixo

representa eventos válidos recebidos pela API.

Novos na v5: colunas `request_id` e `request_hash` (para a C1, com índice em `request_id`) e índice por `company_id` com `transaction_date` (para R20 acumulado e R30).

Novos na v6: nenhuma tabela nem coluna. O perfil sai de consultas agregadas sobre `PIX_TRANSACTION`. Para as estatísticas por contraparte (R1, R4, R5, R33 e a contraparte recorrente, janela de 180 dias), recomenda-se um índice composto por documento do pagador, documento destino e `transaction_date`.

`FRAUD_ANALYSIS`

Uma única análise por evento: `key` (UUID), `transaction_id` (referência única ao evento), `status`, `risk_score`, `rules_version`, `ruleset_hash` e `analyzed_at`. A versão e o hash identificam a configuração que produziu a decisão.

`RULE_HIT`

Cada regra acionada: identificador, chave da análise, código da regra (R1–R33 e C1), pontos antes do teto e detalhe dos valores observados e parâmetros usados.

Relacionamentos: cada `PIX_TRANSACTION` recebe uma `FRAUD_ANALYSIS`; uma análise tem zero ou várias entradas em `RULE_HIT`.

Consultar o histórico de um pagador no banco

A API oferece leitura do evento e da análise por `id` em `GET /pix/transaction/{id}`. Para consultar várias transações de um documento sem acessar uma rota por evento, a migration `database/migrations/003_history_view.sql` mantém a view somente de leitura `v_historico_pagador` e um índice em `rule_hits.analysis_key`.

```
docker compose exec -T db psql -U bootcamp -d epp_conta_compartilhada \
  -f - < database/migrations/003_history_view.sql
```

Conte rejeições nos últimos 60 minutos:

```
SELECT count(*)
FROM v_historico_pagador
WHERE source_document = '<doc>'
  AND status = 'rejected'
  AND transaction_date BETWEEN now() - interval '60 minutes' AND now();
```

Veja o extrato mais recente, incluindo a data de processamento (`created_at`), a decisão e as regras que a explicam:

```
SELECT id, transaction_date, created_at, amount, destination_document,
       status, risk_score, dinheiro_liberado, regras
FROM v_historico_pagador
WHERE source_document = '<doc>'
  AND transaction_date BETWEEN now() - interval '90 days' AND now()
ORDER BY transaction_date DESC
LIMIT 100;
```

`dinheiro_liberado` só é verdadeiro para `approved`; `two_factor_required` ainda aguarda confirmação. Uma rejeição C1 pode ter `risk_score = 0`: C1 força `rejected` sem somar pontos, e a coluna `regras` mostra o motivo. A view cobre transações válidas; tentativas com `409` ou `400`/`422` não são registradas.

Idempotência e concorrência

O motor calcula `payload_hash` (SHA-256) sobre o payload normalizado. O mesmo `id` com o mesmo hash retorna a decisão existente; o mesmo `id` com hash diferente retorna `409`.

Durante a análise, uma transação PostgreSQL usa `pg_advisory_xact_lock` sobre três chaves, sempre na mesma ordem (`id`, pagador, conta destino) para evitar deadlock. Isso serializa requisições do mesmo pagador: uma rajada paralela passa uma de cada vez, cada requisição enxerga o que as anteriores gravaram e o R2 consegue disparar. No EPP, o pagador é a conta da empresa, então R20 acumulado e R30 também leem um histórico consistente. O perfil (v6) é montado na mesma transação, depois das travas, então também enxerga o que as requisições anteriores do pagador gravaram. As janelas de 24 h por documento ou dispositivo (R12 e R26) ficam sem trava, porque uma corrida de milissegundos quase não muda esses sinais; a exceção deliberada, entre empresas diferentes, está no roadmap. Restrições `UNIQUE` em `id` e `transaction_id` são a última barreira contra análises duplicadas.

As janelas históricas usam a `transaction_date` do evento, consideram registros com data menor ou igual a ela e excluem o próprio evento. O evento, a análise e as regras acionadas são gravados na mesma transação, evitando registros parciais.

Como rodar e testar

Requisitos: Docker e Docker Compose. O projeto usa a estrutura do Base Service (Python, FastAPI, PostgreSQL): `PixResource` é a fronteira HTTP/rota e valida o DTO; `PixController` faz o papel da camada de serviço, coordenando idempotência, histórico, motor e gravação; `PixRepository` concentra SQL, locks e persistência. O motor e as regras puras não dependem de HTTP ou SQL. O middleware mantém uma sessão por requisição e o repositório grava evento, decisão e hits na mesma transação.

```
# sobe a API e o PostgreSQL
docker compose up --build
```

A documentação interativa da API fica em `http://localhost:3000/docs` (ou na porta definida por `API_PORT`).

Exemplo de requisição (payload do desafio):

```
curl -X POST http://localhost:3000/pix/transaction \
  -H "Content-Type: application/json" \
  -H "INTERNAL-TOKEN: default_token" \
  -d '{
    "id": "pix-000123",
    "amount": 150000,
    "transaction_date": "2026-10-17T22:15:00-03:00",
    "source_account": {
      "branch": "0001", "account_number": "88213",
      "opening_date": "2025-03-02T10:00:00-03:00",
      "owner": { "document_number": "123.456.789-09" }
    },
    "destination_account": {
      "participant": "60701190", "branch": "3675", "account_number": "10442",
      "opening_date": "2026-10-10T09:00:00-03:00",
      "owner": { "document_number": "987.654.321-00" }
    },
    "source": {
      "device_id": "dvc-9f2c71a8", "channel": "app", "ip": "198.51.100.23",
      "geolocation": { "latitude": -23.56, "longitude": -46.65 }
    }
  }'
```

Com o banco vazio, a resposta é `201` com `status` `two_factor_required` e `risk_score` 2 (só o R6 dispara). Repetir o mesmo corpo devolve `200` com a mesma análise; mudar qualquer campo mantendo o `id` devolve `409`. Para consultar:

```
curl http://localhost:3000/pix/transaction/pix-000123 \
  -H "INTERNAL-TOKEN: default_token"
```

Testes:

```
# em outro terminal, com Docker Compose ativo: instala dependências de dev e roda as regras puras
python3 -m venv .venv
source .venv/bin/activate
pip install -r requirements-dev.txt
python -m pytest tests/test_rules_*.py -q

# cenários HTTP reais, com API e PostgreSQL ativos
python run_api_tests.py pix_api_tests.json --base-url http://localhost:3000
```

O runner da API aceita os placeholders, expande passos `repeat` e testa POST e GET com o token interno padrão; use `--token` ou `INTERNAL_TOKEN` quando ele tiver sido alterado. Ele valida regras, idempotência, consulta do evento armazenado e contratos HTTP.

Cada regra é uma função pura (evento e histórico entram, pontos e motivo saem), então os testes unitários das regras e da combinação (tetos e faixas) rodam sem banco. O runner de API usa o PostgreSQL para conferir decisão, idempotência (`200` e `409`), recuperação do payload original pelo GET, `404` e cenários de concorrência. O POST mantém a resposta `key`, `status` e `metadata`; o GET retorna esses campos e também `transaction` com o evento original gravado.

Cenários de aceitação

Cada linha vira um teste de integração; a coluna "Pontos" é o resultado esperado depois dos tetos, assumindo que nenhuma outra regra dispara.

#	Cenário	Regras	Pontos	Status
1	Payload do desafio (R$ 1.500, destino aberto há 7 dias, sem histórico)	R6	2	`two_factor_required`
2	Mediana de R$ 200 paga R$ 6.000 a um locador novo	R1 + R4 (teto 3) + R5	4	`two_factor_required`
3	Sessão sequestrada de sócio: aparelho novo, 2h10, saída de 87% do saldo livre	R17 + R19 + R20	5	`rejected`
4	Conta de 10 dias, primeiro Pix de R$ 4.900 para conta antiga	R10 (sem perfil)	2	`two_factor_required`
5	Mediana de R$ 1.000 (≥ 5 Pix), 3º Pix entre R$ 4.500 e R$ 4.999 em 24 h para contraparte conhecida	R28	2	`two_factor_required`
6	4º Pix de R$ 1.499 ao mesmo documento, em contas diferentes, em 12 min	R29 (+ R5 se a conta for nova)	2 a 3	`two_factor_required`
7	EPP: 1ª saída de 60% do saldo livre; depois 2ª de 60% do saldo restante em 24 h	1ª: nenhuma; 2ª: R20 (84% acumulado)	0; 2	`approved`; `two_factor_required`
8	EPP, 4 sócios: saída de R$ 40.000 (> 3× a média diária) para CNPJ de outro sócio	R30 + R31	4	`two_factor_required`, com `notify_all_partners`
9	Cenário 8, 6 h depois de reduzir o quórum	R30 + R31 + R16	7	`rejected`
10	EPP: credencial trocada há 3 h, aparelho novo, saída de R$ 8.000 (75% do saldo livre)	R32 + R17 (teto sessão 4) + R20	6	`rejected`
11	`execution` com `request_hash` diferente do pedido aprovado	C1	n/a	`rejected`
12	`request` que cria agendamento (aparelho e contraparte novos); depois a `execution` na data com o mesmo hash	`request`: R5 + R17; `execution`: isenta	3; 0	`two_factor_required`; `approved`
13	Mediana de R$ 200; 6º aluguel de R$ 6.000 ao mesmo locador (relação de 5 meses, maior Pix anterior R$ 6.000)	R1 e R4 isentos (recorrente, dentro da faixa)	0	`approved`
14	Mediana de R$ 8.000 (≥ 5 Pix); Pix de R$ 20.000 a um CPF que só recebeu R$ 5 do pagador	R33 (R1 e R4 não disparam)	2	`two_factor_required`
15	Mediana de R$ 500; 3 Pix de R$ 5 a um CPF e, depois, 4 Pix de R$ 1.499 a ele em 60 min	1º Pix de R$ 1.499: R33; 4º: R29 (soma R$ 5.996; a relação não tem soma nem faixa)	2; 2	`two_factor_required`; `two_factor_required`
16	Mediana de R$ 4.000 (≥ 5 Pix) paga R$ 6.000 a um locador novo	R5 (R1 e R4 não disparam)	1	`approved`

17	Mediana de R$ 4.000; três Pix entre R$ 4.500 e R$ 4.999 em 24 h para contraparte conhecida	R28 não avalia (o R1 não dispararia a R$ 5.000)	0	`approved`

Casos de borda a testar em cada regra nova ou revisada: R28 com 2 vs 3 Pix e R$ 4.499,99 vs R$ 4.500 vs R$ 5.000; R29 com 3 vs 4 Pix, soma R$ 4.999 vs R$ 5.000 e destinatário recorrente; R10 com 2 vs 3 Pix de histórico; R20 em 69% vs 70% acumulados e pagamento coberto por reserva; R30 com 2,9× vs 3× e empresa com 29 vs 30 dias; R31 com recorrente ±20%; R32 com 23 h vs 25 h depois da troca; C1 com pedido ausente, `rejected` e hash diferente; R1 com 2,9× vs 3× a mediana e 4 vs 5 Pix de histórico; R1 e R4 com contraparte recorrente em 2 vs 3 Pix anteriores, 29 vs 30 dias de relação, soma de R$ 999 vs R$ 1.000 e valor de 2× vs 2,01× o maior Pix anterior; R5 com valor abaixo vs acima da mediana; R28 com mediana de R$ 1.666 vs R$ 1.667; R33 com 4,9× vs 5×, R$ 999 vs R$ 1.000 e sem Pix anterior (cai no R5).